



Conception et mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé



Codjo Fréjus Loïc SANGRONIO

Licence Informatique | Option Sécurité Informatique

IFRI-UAC

24 juin 2026

Encadreur :
Ing. Guy KPEDJO

RansomShield

2026-07-07

[OUVERTURE]

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury, bonjour.

Permettez-nous, avant toute chose, de vous exprimer notre profonde reconnaissance pour avoir répondu présents à ce rendez-vous. Ce jour revêt pour nous un cachet tout particulier : il est l'aboutissement de ces années de formation, et un moment qui restera gravé dans notre parcours.

Le sujet ayant fait l'objet de notre étude est intitulé : *Conception et mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé*.

C'est avec fierté et humilité que nous vous présentons aujourd'hui RansomShield — un système conçu et mis en place de bout en bout pour détecter et contrer les attaques ransomware, de manière contrôlée et traçable, avec une validation humaine à chaque étape décisive.

↔ Voici comment s'articule cette présentation.



- 1 Introduction Générale
- 2 Revue de littérature
- 3 Analyse et Conception
- 4 Réalisation et Résultats
- 5 Conclusion et Perspectives

Sommaire	
1	Introduction Générale
2	Revue de littérature
3	Analyse et Conception
4	Réalisation et Résultats
5	Conclusion et Perspectives

[SOMMAIRE]

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury,

Notre présentation s'articule en cinq parties. Nous partirons du contexte et de la problématique qui ont motivé ce travail, pour aller vers un état des lieux des solutions existantes, puis la conception et la réalisation du système. Nous concluons par les perspectives et terminerons par une démonstration en conditions réelles.

↪ Commençons par le contexte et la problématique.



2026-07-07

RansomShield
└ Introduction Générale

Contexte

L'évolution rapide du numérique expose les organisations aux ransomwares : des logiciels malveillants qui rendent les données inaccessibles puis exigent une rançon.

- +73 % d'attaques signalées en 2023 (ENISA)
- Délai moyen de détection **sans outil dédié : 21 jours**
- Coût moyen par attaque : > **1 million de dollars**
- Cibles : PME, hôpitaux, administrations, universités

Objectif général

Concevoir et mettre en œuvre un **système de détection et de réponse aux attaques ransomware** basé sur la surveillance comportementale des fichiers et des processus, avec une console de supervision traçable.

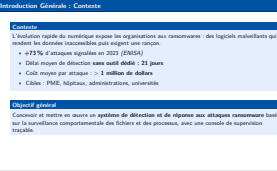
2026-07-07

[CONTEXTE]

Nous entrons dans la première partie de notre exposé, consacrée au contexte et aux motivations de ce travail.

Aujourd'hui, les entreprises, les hôpitaux, les universités fonctionnent grâce à leurs données numériques. Le ransomware — c'est-à-dire un logiciel malveillant qui rend les données inaccessibles puis exige une rançon — exploite précisément cette dépendance. En 2023, ces attaques ont progressé de 73 % selon l'ENISA, avec un coût moyen de plus d'un million de dollars par incident. Ce qui est particulièrement grave : sans outil adapté, une attaque passe en moyenne 21 jours sans être détectée. C'est 21 jours pendant lesquels les dommages s'accumulent en silence.

↔ Ce constat nous amène à la problématique centrale.



Constat

Les antivirus classiques détectent les malwares **connus par leur empreinte**. Face aux variantes nouvelles, ils sont aveugles. Sans outil dédié : **21 jours** en moyenne avant détection — les dommages sont souvent irréversibles.

Problème identifié

Aucune solution open-source, **démontrable en conditions réelles**, n'existe pour la détection comportementale multi-plateforme des ransomwares avec contrôle humain.

Défi #1

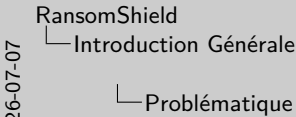
Variantes inconnues contournent les antivirus par signatures

Défi #2

Parc hétérogène (Windows, Linux, macOS) à surveiller

Défi #3

Réponse automatique risquée : contrôle humain indispensable



[PROBLÉMATIQUE]

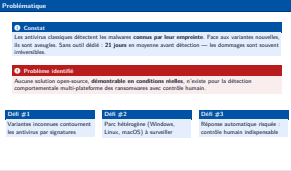
Ce contexte nous amène naturellement à la problématique centrale de ce travail.

Le constat est simple : les antivirus fonctionnent par reconnaissance d’empreintes. Ils connaissent les menaces déjà répertoriées. Mais face à une variante inédite d’un ransomware, ils restent complètement aveugles. Et pendant ce temps, les données sont chiffrées, les sauvegardes effacées, les dommages deviennent irréversibles.

Le problème que ce travail cherche à résoudre est le suivant : il n’existe pas de solution libre et démontrable en conditions réelles pour détecter ces attaques à partir de leurs comportements, avec un contrôle humain intégré à chaque étape.

Trois défis ont structuré ce travail : les variantes inconnues que les outils traditionnels ne voient pas, la diversité des systèmes à surveiller, et le risque qu’une réponse automatique sans validation humaine cause elle-même des dommages.

↔ Ces défis ont défini les six objectifs que voici.



Objectifs spécifiques

- Surveiller les événements fichiers en temps réel sur les terminaux
- Analyser les comportements et calculer un score de risque configurable
- Générer automatiquement des alertes et des incidents de sécurité
- Proposer et exécuter des actions de protection avec **contrôle humain**
- Protéger l'accès à la console par une double authentification (mot de passe + code temporaire)
- Valider l'ensemble du système sur des scénarios d'attaque représentatifs

2026-07-07

RansomShield
└─ Introduction Générale

└─ Introduction Générale : Objectifs spécifiques

Introduction Générale : Objectifs spécifiques
• Surveiller les événements fichiers en temps réel sur les terminaux • Analyser les comportements et calculer un score de risque configurable • Générer automatiquement des alertes et des incidents de sécurité • Proposer et exécuter des actions de protection avec contrôle humain • Protéger l'accès à la console par une double authentification (mot de passe + code temporaire) • Valider l'ensemble du système sur des scénarios d'attaque représentatifs

[OBJECTIFS]

Pour répondre à cette problématique, six objectifs précis ont guidé ce travail.

Premièrement, surveiller en temps réel les activités fichiers sur chaque terminal. Deuxièmement, analyser ces activités pour calculer un niveau de risque. Troisièmement, déclencher automatiquement des alertes dès qu'un comportement suspect est détecté. Quatrièmement — et c'est un principe fondateur — soumettre chaque action proposée à la décision d'un opérateur humain. Cinquièmement, sécuriser l'accès à la console par une double authentification : mot de passe et code temporaire valide 30 secondes. Et sixièmement, valider l'ensemble sur des scénarios d'attaque représentatifs.

↪ Voyons maintenant les fondements théoriques de ce travail.



2026-07-07

RansomShield
— Revue de littérature

Définition d'un ransomware

Un ransomware est un logiciel malveillant qui vise à bloquer l'accès à un système ou à des données, souvent par chiffrement, puis à réclamer une rançon à la victime. (NIST SP 1800-25, CISA)

Comportements caractéristiques (détectables avant les dommages irréversibles)

- Renommage massif de fichiers avec une extension suspecte (.locked, .enc, .crypt...)
- Apparition d'une note de rançon (HOW_TO_DECRYPT.txt)
- Suppression des sauvegardes automatiques du système (points de restauration)
- Détournement d'outils système légitimes pour dissimuler l'attaque
- Suppression massive de fichiers, communications réseau inhabituelles

Ces signaux constituent la base de la **détection comportementale**.

RansomShield
└─ Revue de littérature

└─ Revue de littérature : Définition et comportements

2026-07-07

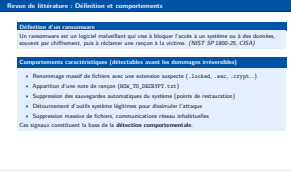
[DÉFINITION]

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury,
Nous entrons dans la deuxième partie de notre exposé : la revue de littérature. Permettez-moi de commencer par définir précisément ce qu'est un ransomware.

Un ransomware agit toujours selon le même schéma. Il commence par accéder à vos fichiers, les renomme avec une extension inhabituelle pour les rendre illisibles, dépose une note de rançon, puis efface les sauvegardes automatiques pour rendre toute récupération impossible. Enfin, il utilise parfois des outils légitimes du système pour masquer sa présence et passer inaperçu.

Ce sont ces comportements observables, ces traces laissées sur le système, qui forment la base de notre approche. Si l'on surveille ces actions en temps réel, on peut réagir avant que les dommages soient irréversibles.

↪ Mais pourquoi les outils existants ne suffisent-ils pas ?



Solutions existantes

- **Antivirus** : détection par empreintes connues (ClamAV, Windows Defender)
- **SIEM** (centralisation des journaux d'activité) : collecte sans analyse comportementale
- **EDR** (surveillance avancée des terminaux) : CrowdStrike, SentinelOne, Defender XDR

Limites des solutions existantes

- ❌ Contournables par variantes nouvelles, obfuscation ou LOLBins
- ❌ Coût élevé des EDR commerciaux (hors portée académique)
- ❌ Absence d'outil open-source académique démontrable en conditions réelles

Notre réponse : RansomShield

Approche comportementale open-source, multi-plateforme, démontrable sur machines virtuelles réelles, avec **contrôle humain à chaque étape**.

RansomShield
└─ Revue de littérature

└─ Revue de littérature : Solutions existantes

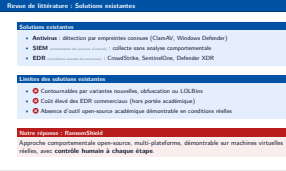
[SOLUTIONS]

Face à cette menace bien documentée, des solutions existent. Voyons pourquoi elles restent insuffisantes pour notre contexte.

Les antivirus ne reconnaissent que les menaces déjà cataloguées dans leur base de données. Les SIEM — systèmes de centralisation des journaux d'activité — collectent des informations, mais sans chercher activement des comportements suspects. Les EDR — solutions de surveillance avancée des terminaux — sont très efficaces, mais leur coût les rend inaccessibles pour la grande majorité des organisations — PME, hôpitaux, administrations, associations — qui n'ont pas les budgets des grands groupes.

RansomShield occupe cet espace laissé vacant : une solution libre, comportementale, déployable sur n'importe quelle infrastructure, avec un contrôle humain intégré à chaque étape — conçue pour les entreprises et organisations qui veulent se protéger sans dépendre de solutions propriétaires coûteuses.

↔ Voyons maintenant comment ce système a été conçu.

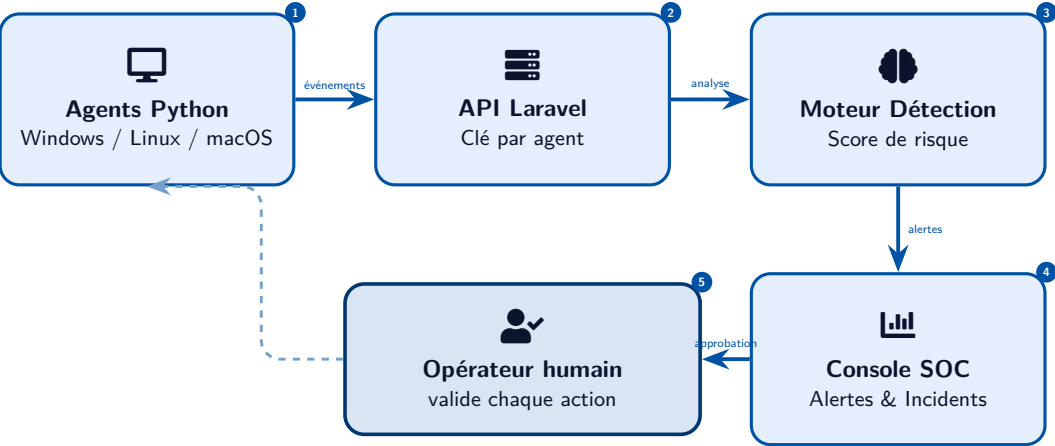


2026-07-07



2026-07-07

RansomShield
Analyse et Conception

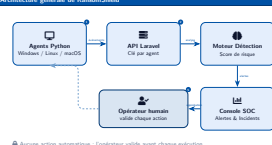


Aucune action automatique : l'opérateur valide avant chaque exécution

2026-07-07

RansomShield

- Analyse et Conception
- Architecture générale de RansomShield



[ARCHITECTURE]

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury,

Nous entrons dans la troisième partie : l'analyse et la conception de RansomShield. Voici l'architecture générale du système — vous pouvez la lire de gauche à droite.

Un agent, installé sur chaque terminal de l'organisation, observe en permanence toute activité inhabituelle sur les fichiers. Ces observations sont transmises au serveur central, qui les analyse et calcule un score de risque. Dès que ce score dépasse un seuil configuré, une alerte est générée automatiquement et une action de protection est proposée à l'opérateur. C'est lui qui prend la décision finale. Le système n'agit jamais seul : chaque intervention est soumise à une validation humaine.

↔ Voyons de plus près les quatre composants.

 Agent de surveillance

Observe en temps réel les activités fichiers sur chaque terminal. Les événements sont **conservés localement** : rien n'est perdu même en cas de coupure réseau. Démarrage automatique au lancement.

 Découverte réseau

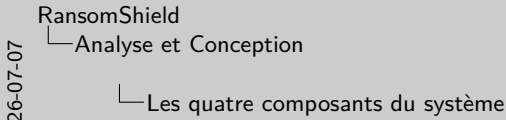
Détecte automatiquement toutes les 5 minutes les nouvelles machines. Aucune n'est intégrée au système sans **accord explicite de l'administrateur**.

 Console de supervision

Tableau de bord actualisé en temps réel. Alertes, incidents, historique des décisions, file d'approbation. Notifications simultanées : web, e-mail, son et webhook.

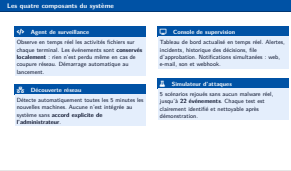
 Simulateur d'attaques

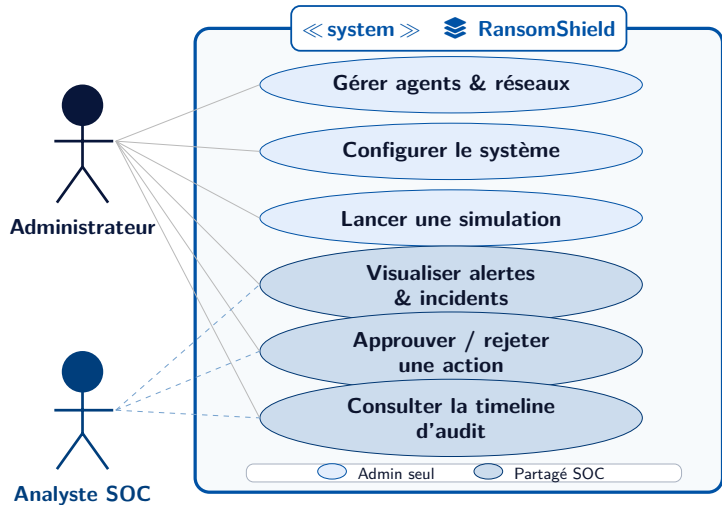
5 scénarios rejoués sans aucun malware réel, jusqu'à **22 événements**. Chaque test est clairement identifié et nettoyable après démonstration.



[4 COMPOSANTS]

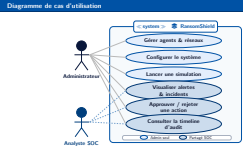
- Voyons maintenant de plus près les quatre composants qui constituent ce système.
- Premièrement, l'agent de surveillance : installé sur chaque machine, il observe en temps réel toute activité inhabituelle sur les fichiers et conserve ces informations localement, pour ne rien perdre même en cas de coupure réseau.
- Deuxièmement, la console de supervision : c'est le poste de commandement, là où l'opérateur suit les alertes, prend ses décisions et consulte l'historique complet de toutes les actions.
- Troisièmement, le module de découverte réseau : il signale automatiquement les nouvelles machines, mais aucune n'est intégrée au système sans accord explicite de l'administrateur.
- Enfin, le simulateur : il reproduit des scénarios d'attaque réalistes, sans déployer le moindre malware réel — ce qui a permis de valider le système en toute sécurité.
- ↪ Qui sont les acteurs qui interagissent avec ce système ?





2026-07-07

RansomShield
└ Analyse et Conception
└ Diagramme de cas d'utilisation



[USE CASE]

Ce diagramme présente les deux profils d'utilisateurs qui interagissent avec RansomShield, et la répartition claire de leurs responsabilités.

L'administrateur configure et pilote le système : il connecte les agents, définit les règles de détection et lance les simulations.

L'analyste SOC — pour Security Operations Center, c'est-à-dire le centre opérationnel de sécurité — traite les incidents au quotidien : il consulte les alertes, approuve ou rejette les actions proposées, et suit l'historique complet des événements.

Cette séparation des rôles est volontaire : l'analyste ne peut pas modifier la configuration, ce qui garantit l'intégrité du système.

↪ Passons maintenant à la réalisation concrète.



2026-07-07

RansomShield
— Réalisation et Résultats

Backend & Base de données

Laravel 11 / PHP 8.3

MySQL 8.0 (Eloquent ORM)

API REST sécurisée (clé per-agent)

Agent de surveillance

Python 3.10

Watchdog (inotify Linux)

SQLite (file locale offline)

psutil (processus)

Frontend

Blade (templates Laravel)

Chart.js (intégré local)

AJAX toutes les 30 s

Infrastructure de test

3 VMs KVM/libvirt

Réseau 10.20.0.0/24

2FA TOTP RFC 6238

Token usage unique (enrôlement)

[CHOIX TECHNIQUES]

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury,

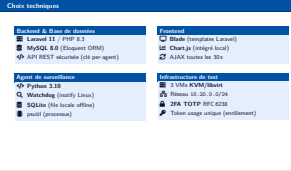
Nous voici dans la quatrième partie de notre exposé, consacrée à la réalisation et aux résultats. Commençons par les choix techniques.

Trois critères ont guidé ces choix : fonctionner sur différents systèmes d'exploitation, être facile à installer, et être démontrable en conditions réelles sans infrastructure coûteuse.

Pour le serveur et la console, le choix s'est porté sur Laravel — un cadre de développement web robuste et éprouvé. Pour l'agent de surveillance, Python, qui offre une excellente portabilité sur Windows, Linux et macOS. L'environnement de test repose sur trois machines virtuelles isolées, reproduisant les conditions d'un vrai réseau d'entreprise.

L'accès à la console est protégé par une double authentification : après le mot de passe, l'utilisateur doit saisir un code temporaire valide 30 secondes seulement.

↪ Voyons concrètement comment l'agent et le moteur fonctionnent.



Fonctionnement de l'agent

- 1 Démarrage et configuration automatique
- 2 Enrôlement sécurisé (jeton à usage unique)
- 3 Surveillance en temps réel des dossiers
- 4 Événements conservés localement
- 5 Transmission sécurisée au serveur central
- 6 Signal de vie toutes les 30 secondes

Installation en une seule commande depuis la console

Scoring comportemental

Signal détecté	Score
Extension suspecte (.locked)	+80
Note de rançon créée	+55
Suppression des sauvegardes système	+60
Outil système détourné	+45
Suppression massive fichiers	+50

Score < 30	Normal	
30 à 59	Suspect	
60 à 99	Élevé	Alerte + incident créés automatiquement en < 5 s
≥ 100	Critique	

2026-07-07

RansomShield
Réalisation et Résultats

Agent Python et moteur de détection

Fonctionnement de l'agent	
1 Démarrage et configuration automatique	
2 Enrôlement sécurisé (jeton à usage unique)	
3 Surveillance en temps réel des dossiers	
4 Événements conservés localement	
5 Transmission sécurisée au serveur central	
6 Signal de vie toutes les 30 secondes	

Scoring comportemental	
Signal détecté	Score
Extension suspecte (.locked)	+80
Note de rançon créée	+55
Suppression des sauvegardes système	+60
Outil système détourné	+45
Suppression massive fichiers	+50
Score < 30 Normal	
30 à 59 Suspect	
60 à 99 Élevé	
≥ 100 Critique	

[AGENT & MOTEUR DE DÉTECTION]

Entrons dans le cœur du système : l'agent de surveillance et le moteur de scoring.

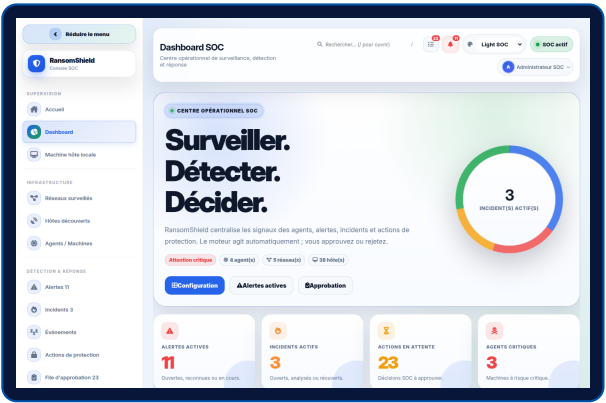
Voici comment fonctionne l'agent au quotidien : dès son démarrage, il est reconnu par le serveur central grâce à un jeton sécurisé à usage unique. Il commence alors à surveiller les dossiers et envoie régulièrement un signal de vie au serveur, toutes les 30 secondes.

Pour illustrer le moteur de scoring : imaginons qu'un fichier soit renommé avec l'extension .locked — cette extension inhabituelle est un signal connu des ransomwares. Ce comportement ajoute 80 points au score de risque. Si en plus une note de rançon apparaît dans le même dossier, 55 points s'ajoutent. Le score atteint 135 — bien au-dessus du seuil critique de 100. En moins de cinq secondes, une alerte est générée et un incident de sécurité est ouvert dans la console. Le système attend ensuite la décision de l'opérateur.

↔ Côté analyste, voici ce que la console SOC offre.

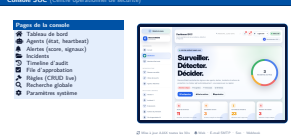
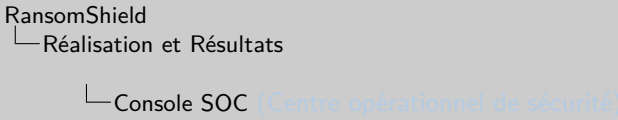
Pages de la console

- Tableau de bord
- Agents (état, heartbeat)
- Alertes (score, signaux)
- Incidents
- Timeline d’audit
- File d’approbation
- Règles (CRUD live)
- Recherche globale
- Paramètres système



Mise à jour AJAX toutes les 30 s · Web · E-mail SMTP · Son · Webhook

2026-07-07



[CONSOLE SOC]

Venons-en maintenant à la console SOC — l’interface que l’opérateur utilise au quotidien pour surveiller, réagir et rendre des comptes.

La console regroupe neuf pages couvrant l’ensemble du cycle de traitement : tableau de bord, gestion des agents, alertes, incidents, timeline d’audit, file d’approbation, règles de détection, recherche globale et paramètres.

Ce qui est fondamental dans RansomShield, c’est que chaque action proposée par le système passe obligatoirement par la file d’approbation. L’analyste l’approuve ou la rejette explicitement. Aucune action ne s’exécute en silence. Ce principe est non négociable.

Dès qu’une alerte est levée, l’opérateur est notifié simultanément par quatre canaux — sur l’interface web, par e-mail, par signal sonore et par webhook — pour s’assurer qu’aucune alerte ne passe inaperçue, quelle que soit sa situation.

↔ Qu’est-ce que les tests ont donné ?

5 scénarios d'attaque testés

Scénario	Évts	Résultat
Chiffrement basique	7	✓
Kill chain complète	22	✓
Chiffrement massif	18	✓
Exfiltration données	8	✓
LOLBins suspects	5	✓

réseau 10.20.0.0/24

3 VMs KVM |

Résultats obtenus

- ✓ Détection en < 5 secondes (tous scénarios)
- ✓ Aucun événement perdu (file SQLite)
- ✓ Pipeline complet validé bout en bout
- ✓ Rollback isolation réseau fonctionnel
- ✓ 2FA TOTP et API sécurisée (per-agent)

Limite identifiée

Tests conduits sur Linux uniquement. Un attaquant ralentissant son rythme réduit la visibilité.

2026-07-07

RansomShield
Réalisation et Résultats

Tests de validation et résultats

[TESTS ET VALIDATION]

Après la réalisation, venons-en aux tests et à la validation du système en conditions représentatives. Une démarche en trois étapes complémentaires a été adoptée.

Premièrement, cinq scénarios d'attaque représentatifs ont été définis, couvrant différents niveaux de complexité : du chiffrement simple à la chaîne d'attaque complète en 22 événements. Ces scénarios ont été construits à partir des comportements réels documentés dans la littérature sur les ransomwares.

Deuxièmement, un environnement de test réel sur trois machines virtuelles en réseau isolé a été mis en place, pour reproduire les conditions d'un vrai parc informatique, sans jamais déployer de malware réel.

Troisièmement, pour chaque scénario, trois indicateurs précis ont été mesurés : le délai de détection, l'intégrité des données transmises, et la complétude de la chaîne jusqu'à la décision de l'opérateur.

Les résultats sont constants : cinq scénarios exécutés, cinq détectés en moins de cinq secondes, zéro événement perdu. Notons honnêtement une limite : les tests ont été conduits sur Linux uniquement — c'est la première perspective d'évolution du projet.

↪ Place maintenant à la démonstration live.



2026-07-07

RansomShield
└─ Réalisation et Résultats

[DÉMONSTRATION LIVE]

Suivre le guide de démonstration.

Checklist rapide :

1. Console SOC ouverte : 3 agents en ligne
2. SSH sur `rs-client-1` : renommage `.locked` + note de rançon
3. Revenir sur la console : alerte critique apparue en moins de 5 secondes
4. File d'approbation : approuver l'action, montrer le rollback
5. Timeline : tout est horodaté
6. Simulation kill chain complète : 22 événements

↔ Revenir à la présentation pour conclure.



2026-07-07

RansomShield
Conclusion et Perspectives

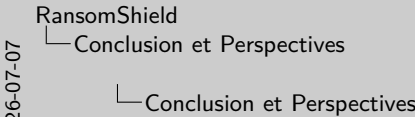
Conclusion

RansomShield est une solution opérationnelle couvrant l'ensemble du cycle de traitement d'un incident : **collecte** → **analyse** → **alerte** → **réponse** → **audit**.

- ✓ Agent Python multi-plateforme : installation en une commande
- ✓ Console SOC : simulation, 4 canaux de notification, rapports PDF, double auth.
- ✓ Moteur de détection : scoring configurable, règles personnalisables, < 5 s
- ✓ Environnement contrôlé : aucun vrai malware déployé

Perspectives d'évolution

- **HTTPS** : chiffrement TLS en production
- **RBAC** (droits par rôle) : profils distincts — administrateur et analyste
- **Machine Learning** : détection des anomalies par apprentissage automatique
- **MITRE ATT&CK** (référentiel mondial des attaques) : couverture et alignement
- **Intégration SIEM** (journaux centralisés) : export vers Splunk / ELK Stack



[CONCLUSION]

Nous voilà dans la cinquième et dernière partie de notre exposé.

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury, permettez-nous de vous présenter la synthèse de ce travail.

RansomShield couvre l'intégralité du cycle de traitement d'un incident de sécurité : la détection sur le terminal, l'analyse comportementale, la génération de l'alerte, la décision de l'opérateur, et l'archivage complet de toutes les actions. Il est opérationnel, démontrable, et construit sans aucun malware réel.

Conscients que cette première implémentation, menée avec des ressources et un délai contraints, n'est pas exempte de lacunes : les tests ont été conduits sur Linux uniquement, et les communications restent en HTTP. Ce sont des limites assumées pleinement et nommées clairement.

Nous n'avons nullement la prétention d'avoir épuisé le sujet. C'est pourquoi nous comptons sur vos observations, vos critiques et vos recommandations pour enrichir ce travail. Chaque remarque du jury est pour nous une opportunité de progresser et de mieux faire.

Les perspectives sont tracées : sécuriser les communications pour la production, affiner les rôles selon le profil de chaque utilisateur, et doter le moteur d'un apprentissage automatique pour qu'il apprenne à reconnaître les comportements normaux et signale les anomalies avec encore plus de précision.



[MERCİ — MOT DE CLÔTURE]

Dans un monde où les systèmes automatisent nos décisions, RansomShield rappelle une conviction simple : la machine peut détecter, mais c'est l'humain qui décide. Ce n'est pas une contrainte technique — c'est un choix éthique.

Merci pour votre aimable attention et pour le temps accordé à ce travail.

[POINTS DE RÉPONSE AU JURY]

- **Python vs C/Go** : Watchdog exploite inotify nativement — CPU minimal, portable Linux/Windows/macOS sans recompilation.
- **Fausse alertes** : Seuils configurables. L'analyste valide ou rejette avant toute action — le système ne peut pas agir seul.
- **Absence de HTTPS** : LAN contrôlé pour ce projet. Chiffrement TLS = première perspective pour la production.
- **Différence avec un antivirus** : L'antivirus reconnaît les empreintes. RansomShield observe le comportement — variantes inédites couvertes.
- **Tests Windows** : Limite assumée — Linux uniquement. Extension à Windows = première perspective d'évolution.